

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-23 07:00 WIB

Top 5 Highlights

- WhatsApp phishing attack uses fake business docs to hack PCs
- FFmpeg fixes PixelSmash flaw in widely used video decoder
- FortiBleed campaign used custom FortiGate sniffer to steal credentials
- VU#936962: Multiple file parsing vulnerabilities in FastStone Image Viewer 8.3.0.0
- Microsoft fixes AutoGen Studio flaw that enabled code execution

Threat Intelligence (10)

01. WhatsApp phishing attack uses fake business docs to hack PCs

An ongoing malware campaign is targeting WhatsApp users in multiple countries with deceptive messages that push VBScript files, leading to remote system access. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/whatsapp-phishing-attack-uses-fake-business-docs-to-hack-pcs/>

02. FortiBleed campaign used custom FortiGate sniffer to steal credentials

Security firm SOCRadar says the large-scale FortiBleed campaign targeting Fortinet FortiGate devices used custom sniffers to harvest authentication secrets from compromised firewalls and steal credentials. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/fortibleed-campaign-used-custom-fortigate-sniffer-to-steal-credentials/>

03. [+24h Old] AryStinger botnet infected thousands of D-Link routers worldwide

A previously undocumented malware botnet named AryStinger has compromised more than 4,000 outdated routers to turn them into proxies for malicious traffic. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/arystinger-botnet-infected-thousands-of-d-link-routers-worldwide/>

04. [+48h Old] Microsoft links Mastra AI supply chain attack to North Korean hackers

Microsoft has attributed a recent Mastra AI supply chain attack that compromised more than 140 npm packages to the North Korean hacking group Sapphire Sleet, also known as BlueNoroff. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-links-mastra-ai-supply-chain-attack-to-north-korean-hackers/>

05. [+48h Old] Webinar: How attackers bypass MFA and how defenders can respond

Modern phishing attacks, including Device Code phishing, can undermine MFA protections and grant attackers access to corporate accounts without stealing passwords. This webinar explores how behavioral AI can help security teams detect compromised accounts faster and automate response workflows. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/webinar-how-attackers-bypass-mfa-and-how-defenders-can-respond/>

06. [+48h Old] The Hacker News Recognizes ANY.RUN as the Best Security Investigation Platform 2026

ANY.RUN has been recognized as the Best Security Investigation Platform 2026 at the Cybersecurity Stars Awards by The Hacker News. This award reflects our dedication to building solutions that make a real impact on daily security operations. At ANY.RUN, we help SOC and MSSP teams worldwide streamline threat investigation workflows through confident decision...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://any.run/cybersecurity-blog/best-security-platform/>

07. [+48h Old] USB worm spreads crypto-stealing malware via Windows shortcut files

Threat actors targeting cryptocurrency wallets have been distributing clipboard-stealing malware with self-spreading capabilities and using the Tor network to conceal communication. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/usb-worm-spreads-crypto-stealing-malware-via-windows-shortcut-files/>

08. [+48h Old] Police cleans nearly 15,000 SocGhosh-infected sites tied to Evil Corp

International law enforcement agencies cleaned nearly 15,000 malware-infected WordPress websites and took down more than 100 servers linked to the SocGhosh

botnet and the Evil Corp Russian cybercrime group. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/law-enforcement-nukes-socgholish-malware-from-nearly-15-000-sites/>

09. [+48h Old] ShapedPlugin update flow hacked to infect WordPress sites

Multiple WordPress plugins from ShapedPlugin were compromised in a supply chain attack that distributed infected releases to paying customers via the vendor's official update system. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.bleepingcomputer.com/news/security/shapedplugin-update-flow-hacked-to-infect-wordpress-sites/>

10. [+48h Old] 5 new security operations roles the AI-SOC will create

For years we've heard the frightening prediction that AI will take jobs away from people. It will and it already is, but that doesn't mean it won't also create new jobs and skills demands - like every other labor trend driven by technology advances. Take security operations for example. Historically, security operations centers (SOCs) were built on a three...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.csoononline.com/article/4186569/5-new-security-operations-roles-the-ai-soc-will-create.html>

Latest Vulnerabilities (10)

01. FFmpeg fixes PixelSmash flaw in widely used video decoder

A newly disclosed FFmpeg flaw dubbed 'PixelSmash' could be exploited for remote code execution on Jellyfin servers under certain conditions, and can also trigger a denial-of-service condition in applications like Kodi, Emby, Nextcloud, PhotoPrism, and OBS Studio. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/ffmpeg-fixes-pixelsmash-flaw-in-widely-used-video-decoder/>

02. VU#936962: Multiple file parsing vulnerabilities in FastStone Image Viewer 8.3.0.0

Overview Two vulnerabilities have been identified in FastStone Image Viewer 8.3 that may allow remote code execution or control-flow corruption when processing specially crafted image files. The affected components include the JPEG 2000 (JP2) parser and the PSD file parser. An attacker can exploit these vulnerabilities by causing the application to automati...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/936962>

03. Microsoft fixes AutoGen Studio flaw that enabled code execution

A vulnerability chain dubbed AutoJack in Microsoft's AutoGen Studio interface for prototyping AI agents could let attackers manipulate an agent into executing arbitrary commands on its host system simply by visiting a malicious webpage. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-fixes-autogen-studio-flaw-that-enabled-code-execution/>

04. VU#226679: Microsoft WinRE allows for bypass of UEFI/BIOS password enforcement

Overview Microsoft Windows Recovery Environment (WinRE) provides a mechanism for recovering and repairing Windows systems using an alternate boot environment. Under certain platform implementations, access to WinRE may allow an attacker to bypass firmware security controls, including administrator-configured UEFI/BIOS passwords. An attacker with physical or...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/226679>

05. [+48h Old] Hackers exploit info disclosure bug in Gravity SMTP WordPress plugin

Threat actors are exploiting an unauthenticated information disclosure vulnerability in the WordPress plugin Gravity SMTP, active on 100,000 sites. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hackers-exploit-info-disclosure-bug-in-gravity-smtp-wordpress-plugin/>

06. [+48h Old] CISA: Splunk Enterprise flaw actively exploited, patch by Sunday

CISA has urged U.S. federal agencies to secure their systems by Sunday against a critical Splunk Enterprise vulnerability that is being exploited in attacks. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisa-splunk-enterprise-flaw-actively-exploited-patch-by-sunday/>

07. [+48h Old] VU#457458: Vendor-signed UEFI applications found vulnerable to Secure Boot bypass

Overview Multiple vendor-signed UEFI applications are vulnerable to Secure Boot bypass via a "Bring Your Own Vulnerable Driver" (BYOVD)-style attack. If a target system trusts the affected vendor's certificate, an attacker can exploit these applications to execute arbitrary code during the early pre-boot phase before the operating system initializes. To mit...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/457458>

08. [+48h Old] Build your own vulnerability harness

We break down the technical architecture behind our multi-stage vulnerability discovery harness and automated triage loop. Learn how we manage state controls, squash false positives through adversarial review, and route around LLM context limits.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://blog.cloudflare.com/build-your-own-vulnerability-harness/>

09. [+48h Old] Attackers abuse Google Ads, GitLab, and Claude to deliver malware

Threat actors are abusing trusted platforms, including Google Ads, GitLab pages, and Claude's shared chat feature, to trick users into executing malicious commands on their systems. Disguised as popular AI developer tools, the threat actors used ClickFix social engineering attacks, where victims were tricked into manually executing malicious commands. Typic...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4186813/attackers-abuse-google-ads-gitlab-and-claude-to-deliver-malware.html>

10. [+48h Old] Apple fixes Beats Studio Buds flaw that let hackers spy on conversations

Apple has released security updates to patch a high-severity flaw affecting the Beats Studio Buds wireless earbuds that could allow attackers in Bluetooth range to spy on users' conversations. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/apple-fixes-beats-studio-buds-flaw-that-let-hackers-spy-on-conversations/>

Data Breach & Cybercrime (10)

01. Prevent data exfiltration: AWS egress controls for cloud workloads

When securing an Amazon Web Services (AWS) environment, teams naturally prioritize inbound controls, firewalls, WAFs, and access policies, because that's where the most visible threats originate. Outbound traffic, on the other hand, tends to get less attention. It's often left open by default to avoid breaking application dependencies and because the risk f...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://aws.amazon.com/blogs/security/prevent-data-exfiltration-aws-egress-controls-for-cloud-workloads/>

02. A Glimpse into the "Search Your Target" Market for Stolen Credentials

Attackers no longer need to sift through massive credential dumps. They can pay others to do it for them. Flare explores how an emerging underground market searches stolen credential databases for specific companies, domains, and accounts. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/a-glimpse-into-the-search-your-target-market-for-stolen-credentials/>

03. [+48h Old] New Prinz Eugen ransomware prioritizes recent files for encryption

A new ransomware operation named 'Prinz Eugen' prioritizes recently modified files for encryption and leaves no ransom note on the system. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/new-prinz-eugen-ransomware-prioritizes-recent-files-for-encryption/>

04. [+48h Old] Klue OAuth breach victim list grows as Icarus hackers claim attack

Market intelligence platform Klue has publicly confirmed a recent security incident that allowed threat actors to steal OAuth tokens used to connect to customers' Salesforce environments, as the new "Icarus" extortion group publicly claims the attack. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/klue-oauth-breach-victim-list-grows-as-icarus-hackers-claim-attack/>

05. [+48h Old] Texas govt data breach exposes over 3 million driver's licenses

The Texas Parks and Wildlife Department (TPWD) disclosed a data breach at its license system vendor that exposed personal information for more than three million individuals. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/texas-govt-data-breach-exposes-over-3-million-drivers-licenses/>

06. [+48h Old] CISA warns Fortinet users to secure devices after FortiBleed leak

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) urged Fortinet customers to secure their devices after nearly 74,000 firewall and VPN credentials were exposed in a data leak dubbed "FortiBleed." [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/cisa-warns-fortinet-users-to-secure-devices-after-fortibleed-leak/>

07. [+48h Old] Gentlemen ransomware uses multiple EDR killers to disable defenses

The Gentlemen ransomware-as-a-service (RaaS) is actively developing and maintaining a suite of endpoint detection and response (EDR) killers to help affiliates evade detection in attacks. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/gentlemen-ransomware-uses-multiple-edr-killers-to-disable-defenses/>

08. [+48h Old] Nintendo confirms data stolen in WebMD subsidiary cyberattack

Nintendo of America has confirmed to BleepingComputer that threat actors stole survey data from the third-party TinyPulse service used internally, but its systems were not compromised. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/nintendo-confirms-data-stolen-in-webmd-subsiary-cyberattack/>

09. [+48h Old] Klue OAuth breach linked to 'Icarus' Salesforce data theft attacks

Market intelligence platform Klue suffered a OAuth breach that enabled the "Icarus" threat actors to steal Salesforce CRM data from multiple organizations in an ongoing extortion campaign. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/klue-oauth-breach-linked-to-icarus-salesforce-data-theft-attacks/>

10. [+48h Old] FortiBleed leak exposes Fortinet VPN credentials for 73,000 devices.

A newly discovered data leak dubbed "FortiBleed" has exposed what appears to be a collection of Fortinet and FortiGate VPN credentials for 73,932 firewall URLs at organizations worldwide. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/fortibleed-leak-exposes-fortinet-vpn-credentials-for-73-000-devices/>